

TO: SolarWinds Leadership and Audit Committee

FROM: Cybersecurity GRC Advisor

DATE: July 2026

RE: SolarWinds SUNBURST — Control Failure and Remediation Analysis

Executive Summary

SolarWinds is a technology company with more than 18,000 customers including federal agencies. The APT-29 group of skilled threat actors breached SolarWinds, resulting in a massive supply chain attack in 2020 affecting the above-mentioned customer base. CISA classified the attack as a grave risk to federal government and critical infrastructure, as the SUNBURST malware was distributed through SolarWinds flagship software, Orion. [CISA AA20-352A]

This document demonstrates that the SolarWinds breach was enabled by compounding governance and control failures, not a zero-day exploit. Known vulnerabilities were documented internally as far back as 2018. The breach was as much of a communication failure as a technical failure. [SEC Complaint; Week 9]

The failure occurred across all three lines at SolarWinds. Line 1 failed to establish a behavioral baseline, with no detection capability and no incident response triggered. Line 2 failed to effectively communicate known risks — CISO Timothy Brown documented vulnerabilities but never escalated to the board level with authority to mandate remediation. Line 3 failed when it approved generic investor disclosures while specific material vulnerabilities were known internally. [SEC Complaint; CISA AA20-352A]

This document recommends four priority remediation actions, maps the controls that should have been implemented, and proposes compensating controls where primary controls require architectural redesign. Named ownership and evidence-based closure are required for every finding. [FERC/E-ISAC; NIST SP 800-37]

Section 1 — Breach Overview and Attack Chain

From March to June of 2020, highly skilled threat actors known as APT-29/Cozy Bear distributed malicious updates to more than 18,000 customers of SolarWinds through a routine software update mechanism. The breach affected numerous IT companies and critical government agencies including the US Treasury, Commerce Department, and DHS. CISA classified the attack, carried out by the Russian Foreign Intelligence Service (SVR), as a grave risk to federal and critical infrastructure.

The attack was first discovered by FireEye on December 8, 2020. CISA issued Emergency Directive 21-01 on December 13, 2020. The precise mechanism of initial access has never been publicly confirmed; multiple investigations describe it as unknown [Senate RPC, 2021]. What is established is the timeline: attackers had accessed SolarWinds' network by September 2019, tested code-injection capability in October 2019, and began distributing trojanized Orion builds by February 2020. Attackers spent nine months undetected inside the SolarWinds environment, establishing a foothold in the Orion build environment by exploiting minimal network segmentation. Attackers inserted malicious backdoor code through a Dynamic Link Library, signed and approved by SolarWinds own legitimate code-signing certificate. [CrowdStrike, January 11, 2021].

CrowdStrike's technical analysis of the SUNSPOT implant revealed the precise injection mechanism. SUNSPOT, a dedicated build-environment implant, monitored the build server for instances of MsBuild.exe, the Visual Studio compiler used to build Orion. When a build was detected, SUNSPOT replaced a single source file, InventoryManager.cs, with a malicious variant containing the SUNBURST backdoor. After compilation completed, SUNSPOT restored the original file and deleted all traces, meaning the repository appeared clean before and after every building. The signed Orion update contained SUNBURST with no visible evidence of tampering at any stage a human reviewer would observe. A third payload, TEARDROP, was subsequently deployed on high-value victim networks for deeper post-exploitation access. [CrowdStrike, SUNSPOT Malware: A Technical Analysis, January 11, 2021]

The backdoor allowed attackers to issue commands via attacker-controlled infrastructure at avsvmcloud.com and use SAML tokens to move laterally into Microsoft cloud environments and email systems of key IT personnel. CISA documented the use of anti-forensic techniques including VPNs to blend victim-country traffic, unpredictable communication delays, and token abuse to evade detection.

The attack vector and CISO Brown's internal statements confirm this was not a zero-day attack but an exploitation of weak internal controls and governance failures. [CISA AA20-352A]

Section 2 — Control Failure Diagnosis

The failure at SolarWinds occurred because controls either failed silently or were never translated into operational processes.

Paper Controls

The attack succeeded because a trojanized update passed undetected because no control existed to verify the origin of the code inside a signed package. A code-signing process existed at SolarWinds; however, it was designed to validate the package, not the integrity of the code inside it. This is a paper control addressing the wrong risk. In practice, two separate controls were required: one validating source code integrity before signing, and another monitoring the build pipeline itself during compilation. CrowdStrike's analysis of SUNSPOT confirmed that the injection occurred during the compilation window, after developer code review and repository commit, but before the compiler read the file. The code-signing process validated the final compiled package, but no control observed the build process during compilation. [CrowdStrike, January 11, 2021; CISA AA20-352A]

Silent Failure Modes

Attackers maintained persistent undetected access to SolarWinds internal environment for nine months. CISA documented the use of anti-forensic techniques including VPN traffic blending, token abuse, and unpredictable communication delays. Monitoring was focused on uptime rather than integrity. Existing tools checked whether systems were running, not whether they had been tampered with. This allowed SUNBURST to remain dormant for approximately two weeks after installation before activating, specifically to evade post-deployment testing. Controls did not merely fail, they failed silently, giving leadership false assurance of security. [CISA AA20-352A]

Ambiguous Ownership and Remediation Planning Failure

Brown's internal assessments from 2018 and 2019 documented a "very vulnerable state" across critical assets, yet no structured remediation followed. By June 2020, Brown acknowledged "our backends are not that resilient" while attackers were already inside. By September 2020, an internal document confirmed security findings had outstripped Engineering's capacity to resolve them. There was no prioritization framework directing resources toward the most critical risks, nor was the organization's risk appetite formally defined or applied to triage findings. SolarWinds lacked explicit ownership, time-bound remediation mandates, documented communication protocols, and escalation paths. Remediation was never verified, never documented, and never subjected to audit or regulatory scrutiny. [SEC v. SolarWinds Corp. and Timothy G. Brown, 2023]

The absence of escalation paths from operational ownership to board-level oversight represents the primary factor contributing to the breakdown of the Three Lines Model.

Section 3 — Risk Analysis (NIST RMF)

RMF Step	Requirements	SolarWinds Failure	Risk Impact	Source
Prepare	Establish foundational organizational, systems, asset risk and enterprise context across all 3 lines.	No risk appetite defined, no risk ownership assigned. Boards never received accurate results.	False security picture presented to the Board. No traceable and verifiable risks, no accountable person.	NIST SP 800-37
Categorize	Clearly defined asset inventory, risk appetite with remediation cycles, impact levels reviewed using high water mark.	Miscategorized the Orion build pipeline. Could not categorize each system in terms of potential CIA failure impact.	Threat actors were able to access and modify critical code repositories. Ripple effect seen on downstream implementation.	NIST SP 800-37
Select	Baseline security established, known organizational context and documented controls.	Wrong control baseline selected for build pipeline. No integrity monitoring, no segmentation controls, no source code validation included.	Chaotic implementation of controls as organization failed to specify its environment context.	NIST SP 800-37
Implement	Know the technology stack, risk appetite, security-privacy plans, documents for collecting evidence.	Code validation existed but control was not thorough enough to verify code integrity during compilation.	Undermined critical risks went unnoticed, creating vulnerabilities throughout the environment. Control design failure.	NIST SP 800-37
Assess	Verifiable controls with documentation, assessment, and remedial action plan with clear milestones.	No independent assessments conducted on build-pipeline controls. Brown's internal findings never converted into formal assessments.	Unverified controls created false assurance. Critical vulnerabilities remained open without formal finding or remediation mandate.	NIST SP 800-37
Authorize	Defined risk and system ownership and accountability, risk response documentation.	No formal authorization process existed for the Orion build pipeline. Assessments never reached Authorizing Officials.	Risks drifted without formal acceptance or rejection. No named official accountable for residual risk decisions.	NIST SP 800-37
Monitor	Environment adapted to automating tasks with defined monitoring strategy.	No continuous monitoring of build environment, no behavioral analytics to flag anomalous activity.	Threat actors established footholds in critical systems for nine months undetected.	NIST SP 800-37; CISA AA20-352A

Section 4 — Root Cause Analysis: Three Lines Model

Line 1 — Operational Failure

In the case of SolarWinds, the operational line failed as there was no baseline for normal environmental behavior established to detect abnormality. Remediation stalled as the operational team lacked defined escalation paths to surface identified risks to Line 2. The incident response team was never triggered while malicious activities were occurring inside the authorized environment, due to the lack of effective communication and failure in continuous monitoring and validation of the internal environment. [CISA AA20-352A]

CISA AA20-352A specifically cited, under Operational Security, the need to improve communication between staff and leadership and external stakeholders, establish paths for communicating with critical contacts and circulating decisions, and outline normal business conduct acceptable on organizational networks.

Line 2 — Risk Ownership Failure

SolarWinds was unable to communicate known risks to senior leadership, disclosing only generic risk information that did not reflect the true risk picture. The SEC charges specifically documented internal assessments stating, "current state of security leaves us in a very vulnerable state for our critical assets" and "access and privilege to critical systems/data is inappropriate," confirming that cybersecurity risk was systematically deprioritized despite documented internal evidence.

The SEC further documented Brown's June 2020 statement that it was "very concerning" that attackers may be using SolarWinds' Orion software for larger attacks because "our backends are not that resilient." The growing volume of security findings was not escalated, and no additional resources were requested. The September 2020 internal document stated, "the volume of security issues being identified over the last month has outstripped the capacity of Engineering teams to resolve." This represents a structural failure where Line 2 could not escalate risks to Line 3, nor provide reasonable assurance for the protection of the Orion product. [SEC v. SolarWinds Corp. and Timothy G. Brown, 2023]

Line 3 and Board — Internal Audit Failure and Board Oversight Failure.

The Board operated under an inaccurate picture of SolarWinds' security posture, as internal assessments documenting critical vulnerabilities were never escalated or independently verified. The gap between internal findings and external disclosures was never identified, giving false assurance of security. No evidence exists of an independent audit function challenging CISO's internal assessments or demanding verification of control effectiveness. SolarWinds was charged with disclosing only generic and hypothetical risks to investors while knowing the actual risks and their implications.

The SEC documented the incomplete disclosure about the SUNBURST attack on December 14, 2020. SEC Enforcement Director Gurbir S. Grewal stated: "Rather than address these vulnerabilities, SolarWinds and Brown engaged in a campaign to paint a false picture of the company's cyber controls environment." [SEC v. SolarWinds Corp. and Timothy G. Brown, 2023]

The collective failure of operational teams without detection baselines, risk ownership without escalation paths, and board oversight without independent verification enabled SUNBURST to persist undetected for nine months.

Section 5 — Compensating Controls and C-SCRM Gap Analysis

Effective compensating controls for the SolarWinds environment address three layers: locking down access to prevent initial entry, limiting blast radius to contain lateral movement, and verifying and watching to detect anomalous behavior. Each layer compensates for a specific control failure identified in the root cause analysis above.

The SUNBURST breach exposed critical gaps in SolarWinds' supply chain control environment across credential management, build pipeline integrity, behavioral monitoring, and network segmentation. FERC/E-ISAC and NIST SP 800-161 both recommend a systemic risk-based approach for protecting critical assets. Where primary control cannot be immediately implemented due to legitimate technical constraints, compensating controls are evaluated against five criteria of adequacy: Rationale, Ownership, Monitoring, Equivalence, and Documentation. [FERC/E-ISAC White Paper, 2021, p. 5; NIST SP 800-161 Rev 1]

Control Gap and Primary Control Mapping (NIST SP 800-53 Rev 5)

Control Gap	Primary Control	Reference
Weak credentials on build server.	IA-5 — Authenticator Management (1) Password Based Authentication.	NIST SP 800-53 Rev 5, Chapter 3, pg. 139
No source code integrity validation.	SA-10 — Developer Configuration Management (1) Software and Firmware Integrity Verification.	NIST SP 800-53 Rev 5, Chapter 3, pg. 274
No behavioral monitoring in build environment.	SI-4 System Monitoring (2) Automated tools and mechanisms for real-time analysis. SI-4 System Monitoring (4) Inbound and outbound communication traffic.	NIST SP 800-53 Rev 5, Chapter 3, pg. 338
No network segmentation.	SC-7 — Boundary Protection (13) Isolation of Security tools, mechanisms, and support components. SC-7 Boundary Protection (21) — Isolation of Systems components.	NIST SP 800-53 Rev 5, Chapter 3, pg. 301-302

Credential Gap — Governance Negligence

The exposure of the "solarwinds123" credential on a public GitHub repository reflects governance negligence rather than a technical constraint. NIST SP 800-53 Rev 5 IA-5 (Authenticator Management) was directly implementable and should have been enforced without exception. No compensating control substitutes for a here, the primary control must be implemented immediately.

ROMED Compensating Controls Table

Control GAP	Compensating Control	R — Rationale	O — Ownership	M — Monitoring	E — Equivalence	D — Documentation
No source code integrity validation	1] Build-time file integrity verification — hash comparison at compiler ingestion. 2] Build server process monitoring. 3] Immutable build	No automated source code integrity scanner was integrated into the existing Orion build pipeline. Integration required pipeline redesign and	Development Security Lead and DevOps Team Lead	Pre-release integrity report generated per build cycle. Reviewed and signed off by Development Security Lead	Build-time hash verification detects file substitution during compilation — the exact SUNSPOT attack vector. Process monitoring catches implants	Exception logs, hash verification records per build cycle, separation of duties sign-off log with named reviewer.

Control GAP	Compensating Control	R — Rationale	O — Ownership	M — Monitoring	E — Equivalence	D — Documentation
	environment. 4] Separation of duties in build process.	potential production downtime. [NIST SP 800-53 Rev 5, SA-10]		before build signing approval.	before injection occurs. Immutable environment eliminates persistent malware between builds.	
No behavioral monitoring in build environment	1] Define behavioral baseline. 2] Dedicated log monitoring team. 3] Centralized out-of-band log storage with 180-day retention. 4] Inbound/outbound traffic policy for build environment (allowlist).	Existing monitoring infrastructure was scoped to uptime and performance only. Rescoping to behavioral integrity analysis required defining baselines, reconfiguring alert tools, and integrating build environment logs. [NIST SP 800-53 Rev 5, SI-4]	SOC Team Lead and Build Environment Administrator	Daily log review by dedicated monitoring team. Weekly anomaly threshold review. Quarterly behavioral baseline revalidation.	Baseline helps detect anomalies. Log monitoring team provides real-time insights functionally equivalent to SIEM. 180-day retention allows attack-vector traceability and allowlist tracks user movement.	Behavioral baseline document. Log retention policy confirming 180-day out-of-band storage. Alert threshold configuration records.
No network segmentation	1] Logical network segmentation via VLANs with single monitored interconnect. 2] Heterogeneous technology stacks across segments. 3] Internal VPN and encrypted tunneling for all cross-segment communications. 4] Privileged Access Workstations (PAW) for build environment access.	Physically separate subnetworks and mission-business function isolation cannot be implemented as it requires considerable infrastructure replacement and downtime. [NIST SP 800-53 Rev 5, SC-7]	Network Security Lead and Infrastructure Team Lead	Monthly VLAN segmentation audit. Real-time alerts on single monitored interconnect. Quarterly PAW access registry review.	Compensating controls create a single monitored chokepoint. Heterogeneous technology stacks deter lateral movement. Internal VPN creates zero-trust internal environment with only specific employee access.	Network architecture diagram showing VLAN configuration. PAW access registry with named authorized users. Internal VPN policy document with cryptographic specifications.

Section 6 — Remediation Plan

Finding	Priority	Remediation Action	Owner	Timeline	Evidence of Closure	Escalation Path
Exposed credential on build server	Critical	Rotate exposed credentials immediately. Remove from GitHub. Force reset all build environment accounts. Enforce IA-5 password complexity policy. Deploy MFA within 30 days. Conduct privileged account audit — remove all unnecessary access.	Security Team, Internal Audit	Immediate — 60 days	Credential rotation log, GitHub removal confirmation, MFA implementation report, privileged account audit trail.	Security Team Lead → CISO → Audit Committee
No source code integrity validation	Critical	Redesign code signing process to include pre-signing integrity verification. Implement build-time hash verification. Separate duties for committing and approving code. Run sandbox analysis before deployment.	DevOps, Security Team	30 days	Hash verification records per build cycle, separation of duties sign-off logs, sandbox analysis reports.	Team Lead → Project Manager → CISO
No behavioral monitoring in build environment	High	Conduct build environment process inventory. Implement SIEM tools integrated with SDLC. Define behavioral baseline. Implement 180-day out-of-band log retention. Review and update log policy.	Network and Security Teams	60 days	Behavioral baseline document, SIEM configuration report scoped to build pipeline, log retention policy confirmation, out-of-band storage verification.	Network Engineer → Project Lead → CISO
No network segmentation of build pipeline	High	Inventory all devices, departments, and users. Define build pipeline network boundaries. Implement VLAN-based logical segmentation. Allocate IP ranges. Implement Privileged Access Workstations. Avoid single points of failure and one-vendor reliance.	Network Team, Project Managers	90 days	Network architecture diagram showing VLAN configuration, PAW access registry, monitored interconnect alert configuration.	Network Security Lead → CISO → Audit Committee

Section 7 — Risk Communication Failures

SolarWinds failed to effectively communicate known risks. The breach was not caused by risks that were unknown, it was caused by risks that were known but never communicated in a form that could drive action.

SolarWinds communication failed precisely at two different points.

Firstly, internal communication. The known documented internal risks were not translated effectively from line 2 to leadership. The risks were found and flagged in technical terms by SolarWinds's CISO Timothy Brown in internal presentations but were never translated into risk language while putting forth in front of leadership. Hence the leaders could not understand and assess overly technical risks, hence could not take effective actions. The lack of defined normal business baseline and absence of out-of-band communication channel were identified by CISA. [SEC Complaint + CISA AA20-352A + Week 9]

Secondly, SolarWinds failed to disclose the risks in a manner which would have painted the exact and true picture, also while creating the urgency to mend it. This reflects the leadership assumed investors understood the risk landscape without being told. The SEC's allegation points out the gap between internal reality and external disclosure of information in SolarWinds communication. Escalation the risk or issues to the right audience is a governance responsibility, not a personal judgement. As the Atlantic Council concluded, SolarWinds represented a failure of strategy far more than a failure of technology. [SEC Complaint + Atlantic Council/Belfer + Week 9]

A strong risk communication strategy in 2018, when Brown first identified critical vulnerabilities, would have required four elements:

- A clear statement of exposure: Our build environment is accessible via a publicly exposed credential, if exploited, attackers could insert malicious code into every Orion update distributed to customers.
- The scale of potential impact: A compromise of the build system would affect every Orion customer, including federal agencies, defense contractors, and Fortune 500 companies.
- The likelihood: The credential has been publicly visible for over a year, this is an active exposure, not a theoretical risk.
- The decision required: We need immediate executive sponsorship to rotate credentials, secure the build environment, implement segmentation, and deploy integrity monitoring.

SolarWinds is a case that underscores the criticality of control integrity and effective risk communication in preventing catastrophic cyber incidents. The breach was a technical failure, but it was a communication failure first.

References

1. Cybersecurity and Infrastructure Security Agency. (2020, December 17; updated April 15, 2021). Alert AA20-352A: Advanced Persistent Threat Compromise of Government Agencies, Critical Infrastructure, and Private Sector Organizations. CISA. <https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-352a>
2. U.S. Securities and Exchange Commission. (2023, October 30; dismissed November 2025). SEC v. SolarWinds Corp. and Timothy G. Brown, No. 23-cv-9518 (S.D.N.Y.). <https://www.sec.gov/newsroom/press-releases/2023-227>
3. National Institute of Standards and Technology. (2018). Risk Management Framework for Information Systems and Organizations (NIST SP 800-37 Rev 2). <https://csrc.nist.gov/publications/detail/sp/800-37/rev-2/final>
4. National Institute of Standards and Technology. (2022). Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations (NIST SP 800-161 Rev 1). <https://csrc.nist.gov/publications/detail/sp/800-161/rev-1/final>
5. National Institute of Standards and Technology. (2020). Security and Privacy Controls for Information Systems and Organizations (NIST SP 800-53 Rev 5). <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>
6. CrowdStrike. (2021, January 11). SUNSPOT Malware: A Technical Analysis. <https://www.crowdstrike.com/en-us/blog/sunspot-malware-technical-analysis/>
7. Federal Energy Regulatory Commission and Electricity Information and Analysis Sharing Center. (2021). SolarWinds and Related Supply Chain Compromise: Lessons for the North American Electricity Industry. FERC/E-ISAC.
8. Atlantic Council Scowcroft Center for Strategy and Security. (2021). SolarWinds and the Failure of Strategy. <https://www.belfercenter.org/publication/solarwinds-attack>
9. Northeastern University. CY6200 Cybersecurity Governance, Risk, and Compliance. Course Material Weeks 8 and 9.